CSTC中国评测 见证质量 技术白皮书

企业数据合规白皮书

（2021 年）

中国软件评测中心·网络空间安全测评工程技术中心

中国计算机行业协会数据安全专业委员会

北京瀛和律师事务所

2021 年 9 月

免费获取行业报告 国外优秀报告中文版
1、每日微信群内分享免费行业研究报告 国外优秀报告中文版
2、每日分享 华尔街日报、金融时报等；
3、每周分享经济学人杂志
所有报告均为公开版，国外报告为独家翻译中文版，包括世界银行、国际清算银行、世界经济论坛、IMF、国外知名智库和咨询公司报告，仅用于内部学习！

请添加微信DDKJZX8或扫描二维码，
加入“点滴科技”微信群！

版权声明

本白皮书版权属于中国软件评测中心，并受法律保护。转载、摘编或利用其他方式使用本白皮书文字或观点的，应注明“来源：中国软件评测中心”。违反上述说明的，本单位将追究其相关法律责任。

CSTC中国评测

编写小组：（按字母排序）

白利芳　曹顺超　陈　靖　陈泽伟　顾宁伦　高志欢
耿冠和　韩志峰　黄斐一　黄学臻　李晓明　李维娜
李松恬　李志鹏　李　研　刘　欣　刘芮汐　刘心蕾
刘金春　梁　潇　龙　飞　卢佐华　孟　斌　马传良
马多贺　申　伟　宋岳峰　唐　刚　田　峰　王东阳
王婧宇　王雪琼　魏　来　魏向杰　文雪刚　吴连勇
谢　懿　徐世权　许振喜　薛竹君　杨　继　叶茂祥
于　乐　张久珍　张　宏　张士莹　张　峰　张　兵
张晓娜　张弘扬　张建荣　赵礼杰　郑　东　周　鹏
周庆山　朱信铭　朱宇泽　左　冉

编写单位：

中国软件评测中心（工业和信息化部软件与集成电路促进中心）

中国计算机行业协会数据安全专业委员会

北京瀛和律师事务所

CSTC中国评测

参研单位：（按笔画排序）

上海观安信息技术股份有限公司
公安部第一研究所
中国电子信息产业集团有限公司第六研究所
中国电信集团有限公司
中国电信股份有限公司研究院
中国联合网络通信有限公司
中国移动通信集团有限公司
中国科学院信息工程研究所
中核核信信息技术(北京)有限公司
北京大学信息管理系
北京梆梆安全科技有限公司
北京天融信网络安全技术有限公司
北京安瑞科技有限公司
北京知人善用信息技术有限公司
北京软件和信息服务业协会
西安邮电大学
西安千喜网络科技有限公司
全球能源互联网研究院有限公司
远江盛邦（北京）网络安全科技股份有限公司
启明星辰信息技术集团股份有限公司
国家互联网应急中心
奇安信科技集团股份有限公司
陕西泽众维密信息技术有限公司
绿盟科技集团股份有限公司
联通数字科技有限公司
新华三信息安全技术有限公司
蔷薇大树科技有限公司
蔷薇聚信（北京）科技有限公司
ISC2 北京分会

CSTC中国评测

CSTC中国评测

目 录

前　言 ..... - 1 -

总 则

一、数据合规价值观 ..... - 3 -

（一）国内价值观 ..... - 3 -

（二）国际价值观 ..... - 3 -

二、数据合规法律环境 ..... - 4 -

（一）国内法律环境 ..... - 4 -

（二）国际法律环境 ..... - 6 -

分 则

一、金融科技行业数据合规 ..... - 15 -

（一）金融科技行业数据合规现状分析 ..... - 15 -

（二）金融科技行业数据合规要点 ..... - 18 -

（三）金融科技行业数据合规治理方案 ..... - 20 -

（四）金融科技行业数据合规法律法规焦点问题 ..... - 22 -

二、智能汽车行业数据合规 ..... - 24 -

（一）智能汽车行业数据合规现状分析 ..... - 24 -

（二）智能汽车行业数据合规要点 ..... - 26 -

（三）智能汽车行业数据合规治理方案 ..... - 30 -

（四）智能汽车行业数据合规法律法规焦点问题 ..... - 33 -

三、在线教育行业数据合规 ..... - 35 -

（一）在线教育行业数据合规现状分析 ..... - 35 -

CSTC中国评测

（二）在线教育行业案例及数据合规要点 . . . . . - 37 -
（三）在线教育行业数据合规治理方案 . . . . . - 43 -
（四）在线教育行业数据合规法律法规焦点问题 . . . . . - 45 -
四、电信和互联网行业领域数据合规 . . . . . - 46 -
（一）电信和互联网行业数据合规现状分析 . . . . . - 46 -
（二）电信和互联网行业数据合规要点 . . . . . - 51 -
（三）电信和互联网行业数据合规治理方案 . . . . . - 52 -
（四）电信和互联网行业法律法规焦点问题 . . . . . - 55 -

CSTC中国评测

前　言

在全球数字经济发展的大背景下，数据已成为企业的重要资产。2021 年 6 月 10 日，第十三届全国人民代表大会常务委员会第二十九次会议审议通过了《中华人民共和国数据安全法》（以下简称《数据安全法》）。该法已于 2021 年 9 月 1 日起施行。《数据安全法》作为我国数据安全领域的基础性法律，明确了数据安全领域内治理体系的顶层设计，通过规制数据处理活动、保障数据安全、保护个人和组织合法权益、维护国家主权和安全，引领和促进数据的开发利用，要求企业依法强化合规建设，对企业与机构的责任、义务提出了更加细致的规范和要求。其中第一章明确要求“应建立健全数据安全治理体系，提高数据安全保障能力”。

为推进数据合规工作，排除企业数据合规风险，本白皮书基于企业数据合规工作的必要性，首先对国内外数据合规价值观和法律法规环境进行了概述；然后对金融科技、智能汽车、在线教育、电信及互联网四个重要领域的数据合规现状、要点、治理方案、法律法规焦点问题进行了详细介绍。

中国软件评测中心（工业和信息化部软件与集成电路促进中心），简称“中国评测”，是工业和信息化部直属单位，创立于 1990 年。成立 30 年来，中国评测秉承“诚信、担当、唯实、创先”的核心价值观和“专业就是实力”的宗旨，先后承担了 10 万余款软硬件产品和 1 万余项信息系统工程的测试任务，已成为国内权威的第三方软、硬件产品及信息系统工程质量安全与可靠性检测机构。中国评测的业务网络覆盖全国 500 多个城市，出具的测试报告在 61

个国家和地区实现互认。

中国软件评测中心网络空间安全测评工程技术中心致力于信息系统的网络安全防护和安全运行，支撑政府主管部门履行网络安全相关的社会管理和公共服务职能。长期服务和支撑国家部委、地方政府以及电信、交通、能源、银行、证券、保险、教育、卫生、广电等各大行业，提供网络信息安全战略咨询规划、网络安全平台设计咨询、信息安全风险评估、网络安全等级保护测评、关键信息基础设施保护评估、数据安全能力和合规性评估、APP 安全认证检测、商用密码应用安全性评估等网络信息安全相关服务。

在此感谢各高校、企业和研究机构有关专家对本白皮书的撰写指导，限于研究时间有限，报告内容难免存在纰漏，不足之处恳请各方同仁批评指正！中国软件评测中心非常期待能够与各行业、各领域专家进一步合作，共同推进企业数据合规工作。

CSTC中国评测

总则

一、数据合规价值观

（一）国内价值观

我国将数据定位为新型生产要素，数据作为新型生产要素，已正式与土地、劳动力、资本、技术等传统生产要素并列为国家基础战略性资源和社会生产创新要素之一。首部数据安全基础法《中华人民共和国数据安全法》已颁布，个人信息保护相关法律已经出台，围绕数据合规、数据治理的政策标准及体制体系研究正加紧开展，国内数据合规政策环境趋于明朗。我国各行业数据资源丰富，价值优势突出，利益相关方蜂拥而至，且随着各行各业数据内外部应用的同步拓展和推进，数据合规问题日益凸显，严重阻碍数据资源价值释放，数据合规需求更加迫切，数据合规研究及指导落地刻不容缓。

（二）国际价值观

国际上对数据资源高度重视，各国纷纷采取数据本地化等强制性措施，维护数据主权并争夺数据资源。国家间、企业间数据资源的争夺日益激烈，“数据主权”面临严重挑战。**一方面，**很多国家或组织通过强制数据本地化存储、强制性反加密制度（如强制性后门）等加强对数据获取、数据跨境流动及合作等方面的控制权。欧盟数据相关立法密集，深刻影响国际安全治理格局，

包括美国、日本、韩国、印度等在内的十几个国家为打通欧盟立法产生的数据壁垒，与其已经达成或正在谈判以达成数据传输保护协议。**另一方面，**以美国为首的多个国家通过单方面主张域外管辖权获取境外数据，意图创建打破数据本地化政策的全新规则框架，但又以网络自由原则和人权保护为理由，对外国政府调取数据均以自身利益为先加以制衡。在数字经济全球化的当下，迫使包括中国在内的数据治理主体在数据相关战略部署，及中国企业在内的跨境数据运营主体在业务合规过程中，必须考虑、评估国际政策法律环境的约束和实际影响力。

二、数据合规法律环境

（一）国内法律环境

国内数据合规政策、立法多头并进，数据治理迎来新格局。2015 年 7 月 1 日，《中华人民共和国国家安全法》颁布并施行，同日，国务院办公厅印发《关于运用大数据加强对市场主体服务和监管的若干意见》，提出充分运用大数据先进理念、技术和资源，加强对市场主体的服务和监管，推进简政放权和政府职能转变，提高政府治理能力。2017 年 6 月 1 日，《中华人民共和国网络安全法》正式施行，其中对个人信息保护作出明确规定。2018 年 8 月 31 日，我国《电子商务法》公开颁布，除了对个人信息保护做出规定外，对于“数据杀熟”问题也首次尝试做出回应。

2019 年 5 月 28 日，国家互联网信息办公室发布《数据安全管理办法（征求意见稿）》，对利用网络开展数据收集、存储、传输、处理、使用等活动，以及数据安全的保护和监督管理，做了详细规定。6 月 13 日，发布《个人信息出境安全评估办法(征求意见稿)》，目前两项公开征求意见工作已完成。10 月 1 日，由国家互联网信息办公室发布的《儿童个人信息网络保护规定》正式施行。12 月 1 日，等保 2.0 正式将大数据安全纳入监管体系。

2020 年 1 月 1 日，《中华人民共和国密码法》正式施行。1 月 17 日至 18 日，中央政法工作会议强调，要把大数据安全作为贯彻总体国家安全观的基础性工程，依法严厉打击侵犯公民隐私、损坏数据安全、窃取数据秘密等违法犯罪活动。3 月 30 日，中共中央、国务院印发《关于构建更加完善的要素市场化配置体制机制的意见》，提出“加快培育数据市场要素”，优化经济治理基础数据库，培育数字经济新产业、新业态和新模式，加强数据资源整合和安全保护。4 月 27 日，国家互联网信息办公室、国家发展和改革委员会、工业和信息化部、公安部、国家安全部等 12 部门联合制定发布《网络安全审查办法》，明确网络安全审查重点评估采购网络产品和服务可能带来的国家安全风险，包括网络产品和服务使用后带来的关键信息基础设施重要数据被窃取、泄露、毁损的风险。5 月 28 日，十三届全国人大三次会议表决通过《中华人民共和国民法典》，其中专设了“隐私权与个人信息保护”章节。

2020 年 6 月 28 日，我国第一部在数据安全领域的基础性法律《中华人民共和国数据安全法（草案）》在第十三届全国人大常委会第二十次会议通过审议，并于 7 月 3 日在中国人大网公开征求意见，随后《中华人民共和国个人信息保护法（草案）》公开征求意见。诸多政策、立法齐头并进，为数据及其安全治理落地实践提供全面保障。2020 年 7 月，我国对外公布了《数据安全法（草案）》的征求意见稿，其在法律地位上与《网络安全法》《国家安全法》相一致。

2021 年 6 月 7 日，为促进国家数字经济的发展，维护国家数据安全，《中华人民共和国数据安全法》（草案三次审议稿）提请第十三届全国人大常委会第二十九次会议审议。2021 年 6 月 10 日，国家主席习近平签署第八十四号主席令，公布《中华人民共和国数据安全法》，并自 2021 年 9 月 1 日起施行。该法是继《网络安全法》之后，又一部网络安全领域的重要法律，既是国家数据安全领域的基础法，又与其他相关法律相联系。《数据安全法》的出台，不仅有助于我国数字经济与国际接轨，同时为国家数字经济发展保驾护航，对指导我国数据行业安全规范运营具有重要意义。

（二）国际法律环境

1 欧盟

欧盟立法密集，深刻影响全球数据安全治理格局。2016 年 4

月27日，欧盟发布2016/679号条例《通用数据保护条例》（GDPR），取代95/46/EC号指令（欧盟数据保护指令）。条例制定了个人数据保护的一般规范，为欧盟内外个人数据的自由流动提供了确定性保护，开启了其成员国新一轮数据立法，是欧盟新形势下数据治理的里程碑事件。7月6日，首部网络安全相关法律《网络与信息系统安全指令》（NISD）颁布，旨在加强基础服务运营商、数字服务提供商的网络与信息系统安全，并要求成员国及时转化为国内立法，与 GDPR 分别从安全和基本权利保障两个层面实现其网络治理战略意图。

2018年10月23日，第2018/1725号条例《联盟机构个人数据处理保护条例》发布，其作为GDPR的补充，对欧盟机构在处理个人数据时对自然人的保护提出基本要求，明确了数据主体的权利范围及主要监管机关的职能和义务。为保障非个人数据在欧盟境内自由流动，更大程度地激发和释放数据价值，2018/1807号条例《非个人数据自由流动条例》于11月14日发布，该条例对数据本地化要求、主管当局的数据获取及跨境合作、专业用户的数据迁移等问题作出了具体规定，并考虑了服务提供商负担过度及市场扭曲等问题，进一步完善了欧盟数据治理框架。欧洲数据保护委员会的统计数据显示，在GDPR实施的第一年里，成员国共报告28100多例 GDPR 违规案件，罚款总额达55,955,871欧元（其中5000万欧元为对谷歌的罚款）。另根据GDPR执法追踪网站（enforcementtracker.com）的统计，截至2020年9月，欧盟

成员国共开出 362 张与 GDPR 相关的罚单，总罚款金额高达 491,003,290 欧元，平均每单处罚 1,356,363 欧元，其中“对数据进行处理的法律依据不足”“缺乏足以保障数据安全的技术和组织措施”“违反数据处理的一般原则”等三种违法情形位居罚单数量和金额前三甲。

2019 年 4 月 17 日，第 2019/881 号条例《关于 ENISA 和信息通信技术网络安全认证的条例》(又称《2019 网络安全法案》)正式颁布，这是欧盟网络安全治理的里程碑事件。法案指定欧盟网络和信息安全署（ENISA）为永久性欧盟网络安全机构，确立了第一份欧盟范围的网络安全认证计划，以确保向欧盟境内提供的产品、服务满足其网络安全标准。6 月 20 日，《数据开放指令》发布。

欧盟的“数据”和“安全”相关法律密集出台，与其“数字化单一市场”战略齐头并进，培育了良好的数据安全治理环境，深刻影响国际数据治理格局。在美国曝光监听丑闻及棱镜事件后，欧盟认为欧美长达 15 年的《安全港协议》不足以保护欧盟公民隐私。2016 年 2 月 2 日，美国与欧盟达成新的隐私盾（Privacy Shield）协议，新协议要求美国企业履行更加严格的义务以保护欧盟公民的个人数据，且必须做出相应承诺。2019 年 1 月 23 日，日本与欧盟达成数据共享协议，在欧盟对其进行充分性认定前，日本实施了额外的保障措施，以确保由欧盟转移的数据享有符合欧洲标准的保护保障，并至少每四年进行一次协议运作审查。

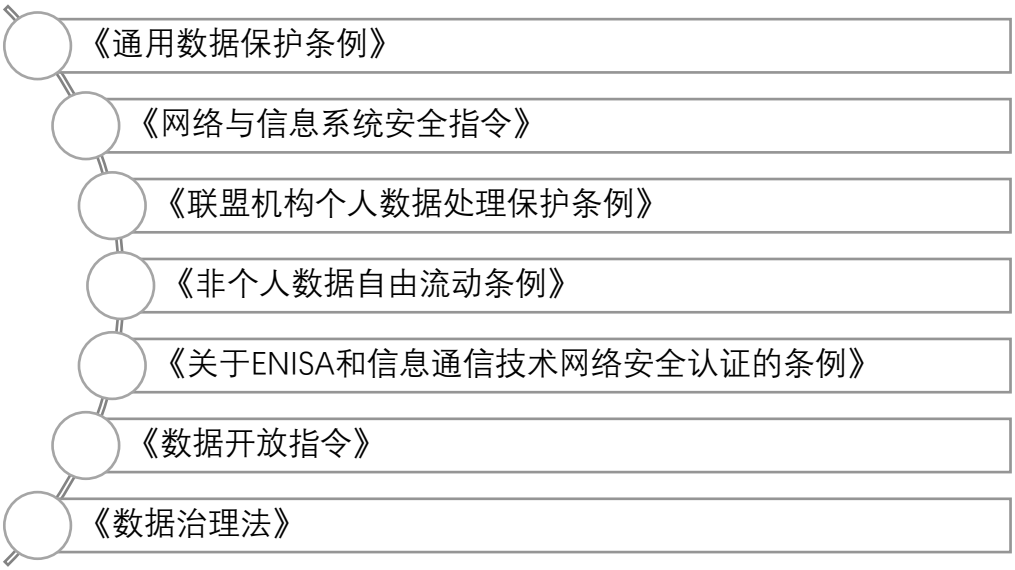
与此同时，欧盟为 AI 数据采集立法，开创个人隐私保护监管先河。欧盟委员会于 2020 年 4 月 21 日正式发布一项针对 AI 的法律监管框架。这份长达 81 页的立法草案指出，欧盟将禁止使用人工智能系统建立社会征信体系，同时将彻底禁止一些对个人隐私构成“高风险”的人工智能应用。这意味着未来不符合准入标准的 AI 系统，可能无法进入欧盟。

2020 年 11 月 4 日，欧盟推出与美国共享数据的合规条款。欧盟委员会发布更新的标准合同条款（SCC），概述公司和组织如何与美国共享数据而又不违反欧盟的隐私法律。SCC 为欧洲公司与美国和其他第三方国家/地区交换数据提供了一种法律机制，将使得欧洲组织能明确在什么情况下进行跨境数据传输是合法的。

2020 年 11 月 25 日，欧盟发布《数据治理法》的提案，旨在通过增加对数据中介机构的信任并通过加强整个欧盟的数据共享机制来促进使用数据的可用性。

2021 年 7 月 22 日，荷兰数据保护局以侵犯儿童隐私为由，决定对字节跳动旗下短视频社交平台 TikTok（“抖音”国际版）处以 75 万欧元的罚款。这一事件意味着欧盟《通用数据保护条例（GDPR）》（“GDPR”）实施三年以来，中国企业（包括其控制的海外平台）第一次因违反 GDPR 相关条款而遭受处罚，具有一定标志性意义。欧盟的数据安全相关政策法律视图如图 1 所示:

图 1：欧盟的数据安全相关法律政策视图



2 美国

美国多点式进行数据立法，捍卫其多元化社会利益。目前美国尚无联邦层面的、正式的综合性数据安全立法，但美国从联邦层面多次强调将数据作为执法优先项，并于 2019 年底相继提交《国家安全和个人数据保护法提案》《数据保护法提案》。

2018 年 6 月 28 日，美国在州层面通过第一部数据隐私法案《加利福尼亚州消费者隐私保护法》(CCPA)，并于 2020 年 1 月 1 日正式生效。法案强化了数据主体对个人信息的控制权，规范了企业收集处理数据的方式。此前，在 2018 年 1 月，特朗普签署了《外国情报监视法案修正案》第 702 条的更新授权，延续其霸权形式的互联网监视及情报收集计划，同意授权美国国家安全局(NSA)监听境外目标人员并收集其相关数据情报。2018 年 3 月 23 日，特朗普签署《澄清合法使用海外数据法》即“CLOUD 法案”，

法案提升了美国执法机构对境外存储数据的执法权限，即无论网络服务提供商的数据是否存储在美国境内，只要是提供商拥有、控制或监管，均须按照该法令的要求保存、备份和披露。同时允许“适格外国政府”执法机构调取美国存储数据，但“适格”认定、调取规则以及上述域外数据采集要求均以美国利益为先加以制衡。

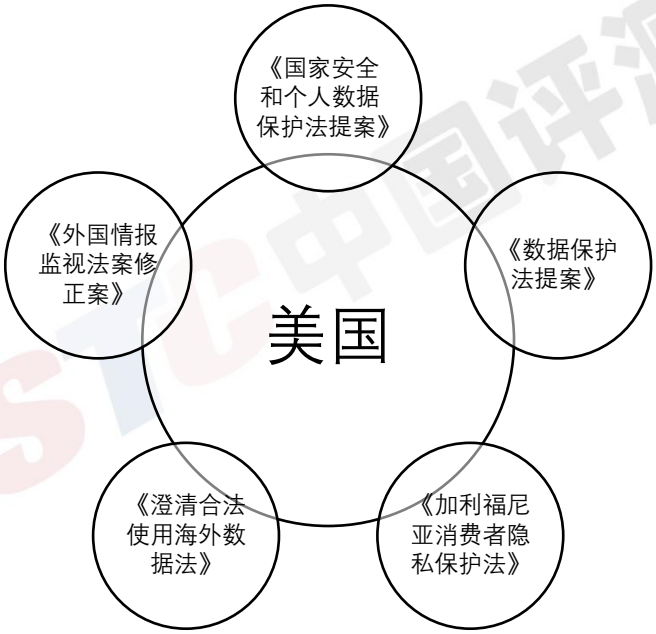
2020 年 12 月，美国颁布《外国公司问责法》，要求在美上市公司披露额外信息，其中包括提供符合美国证券交易委员会的审计标准的审计报告。该法律规定，如果外国公司连续三年没有通过美国公众公司会计监督委员会的审计，那么将不能在美国任何交易所上市。此外，依据美国《萨宾斯-奥克利》法案，上市公司必须在审计报告中提供“内部控制”内容，通常包括网络活动、帐号活动、数据库活动、用户活动、系统登入活动以及信息接入的参数和条件等等。值得关注的是，审计报告中必须包含公司在网络安全信息基础建设中的相关内容，其审计底稿中可能需要包括关键信息基础设施的详细参数。

美国实施网络监控，威胁全球数据安全。美国领导的“五眼联盟”以所谓“维护公共安全”为由，要求一些高科技公司在加密应用程序中插入“后门”，以便为“五眼联盟”开展“网络执法行动”提供便利。英国《计算机周刊》网站刊文指出，此举与真正的数据安全原则背道而驰。“棱镜门”“方程式组织”“梯队系统”等旧账未了，如今又公然要求高科技公司给自己开“后门”，

这进一步暴露了美国在网络安全问题上的双重标准。

事实上，美国才是全球最大的网络攻击者，长期在全球实施大规模网络监控，是名副其实的“黑客帝国”。俄罗斯联邦安全会议副秘书奥列格·赫拉莫夫说，美国不断强化针对别国网络空间的侦察和破坏活动，同时还指责他国是网络威胁的主要来源。“世界上大部分网络攻击都是由美国发起的”。美国的数据安全相关政策法律视图如图 2 所示:

图 2：美国的数据安全相关政策法律视图



3 其他国家以及国际组织

国际数据治理情绪高涨，配套政策出台密集。2017 年 5 月 30 日，日本《个人信息保护法》修订版全面施行。2018 年 2 月 22 日，澳大利亚隐私法修正案《数据泄露通知计划》正式施行。6 月 12 日，越南通过《网络安全法》，对个人信息保护作出规定。

8 月 14 日，巴西批准了《通用数据保护法》。11 月 5 日，加拿大《个人信息保护和电子文件法》修正案生效，增加了强制性数据泄露通知报告要求。2019 年 12 月 4 日，印度内阁通过《个人数据保护法案》，引入了更为广泛的数据本地化要求，对包括互联网行业在内的多个行业带来全面冲击。2020 年 5 月 14 日，新加坡通信信息部和个人数据保护委员会联合发布《个人数据保护法（修订）》草案，是规范个人数据的收集、使用和披露的综合性立法。为配合该法更好执行，当地还配套出台了特定领域（如电信、房地产、教育、医疗、社会公益服务等行业）的个人数据保护指南。

美国主导下的亚太隐私数据跨境体系（APEC CBPRs）在经历沉寂期后迎来实质性进展。2018 年 3 月，新加坡加入 CBPRs 体系；11 月，澳大利亚和中国台北的加入申请也同时获得 APEC 批准。截至目前，在 APEC 21 个经济体中，已有美国、日本、加拿大、韩国、新加坡等 8 个经济体加入 CBPRs 体系。ODCE 经合组织也在继 2013 年 7 月发布《隐私及个人数据跨境流动保护指引》后，于 2019 年 11 月，发布《公共部门如何实现数据驱动》的报告，以促进公共部门采用更多数据驱动的方法来制定政策、提供服务，并提出关于建设数据驱动型公共部门的建议。

2020 年 6 月 12 日、6 月 30 日、7 月 3 日、9 月 2 日，欧盟、丹麦、英国和法国分别启动针对 TikTok 涉嫌违反 GDPR 的调查。越来越多的国家对数据保护实行严格监管，这是我国企业跨国运

营所面临的“头号麻烦”。面对数据保护处罚的威胁，不愿或无力承担合规成本的企业往往选择退出“高风险”的市场，而选择坚守的企业则采取积极的应对措施降低违规风险。一些在境外运营的中资互联网企业使用第三方云服务提供商（符合 GDPR 安全标准）对用户数据进行存储和管理，并与企业分担合规责任。根据字节跳动与甲骨文于 2020 年 9 月 13 日达成的关于 TikTok 美国业务的协议，甲骨文正式作为 TikTok 可信赖的数据安全合规合作伙伴，有权对 TikTok 美国的源代码进行安全检查，从而代表美国政府解决美国国家安全问题的意志。

日益严格的数据保护已对跨境投资造成了负面影响。德勤会计师事务所发布的《2020 并购趋势报告》指出，在欧盟 GDPR 和美国加州 CCPA 相继实施、生效的背景下，70%的受访企业代表认为对并购的数字资产的保护是个值得关注的问题; 数据安全的合规要求对企业并购的尽职调查和并购整合而言都构成潜在的风险。美国伊利诺伊技术学院 Jian Jia 等人于 2019 年 12 月发表了论文《GDPR 与风险投资的本地化》，分析了 GDPR 实施一年以来欧盟外部和欧盟内部的风险投资变动情况。结果显示，欧盟外部对欧盟的风险投资、欧盟内部成员之间的风险投资、同一欧盟国家内部的风险投资的平均单笔交易美元金额分别下降 41.89%、35.77%和 28.02%，交易数量分别减少 26.29%、20.71%和 13.67%。

分则

一、金融科技行业数据合规

（一）金融科技行业数据合规现状分析

不谋全局者不足以谋一隅，以史为鉴可以知兴替。2020 年下半年起各金融科技公司上市趋势陡然放缓、金融科技公司科创板上市政策亦陆续收紧，金融科技的未来监管趋势成为业界关注的重点话题。此后，央行、银保监会围绕“金融科技的本质是金融”这一核心观点持续发声、出台政策。回顾过往，人们会发现，这一观点并非突然而降，央行、银保监会在此之前（公开信息可以追溯至 2017 年）便多次提及。站在今天的时点，谈及金融科技的数据合规监管，必须考虑“金融科技的本质是金融”所带来的特别监管要求。本部分将从中国金融科技的发展史与监管史的对照中，对未来的监管趋势进行分析。

1 中国金融科技发展、监管史

中国金融科技的发展和监管历程，可以用“**国家队持续筑基，市场队开疆拓土，最终迎来爆发式发展，监管放管结合**”来形容。

表 1：中国金融科技各技术领域发展、监管史

技术领域	发展进程及监管史
支付清算技术	建国至改开初期，是全国手工联行的手工操作阶段。
	进入 20 世纪 90 年代，全国电子联行系统上线，中国进入金融科技初步发展阶段。
	2000 年后，大小额支付系统等的上线运行，开启中国现代化支付系统（CNAPS）一代时期，中国的支付清算技术从一穷二白逐步进入世界先列；随着国家队 CNAPS 一代的上线和中国电子商务的发展，第三方线上、线下支付技术自 2005

	年开始，进入了快速发展，支付宝、微信支付、网银在线、拉卡拉、银联商务等发展迅猛。
	2010 年，网上支付跨行清算系统（超级网银）率先上线，2013 年 CNAPS 二代正式切换上线（大小额支付系统升级二代，清算账户管理系统、支付管理信息系统、公共管理控制系统上线，相关系统配套改革升级），中国的支付清算技术进入世界领先地位；国家队夯实基础的同时，第三方支付爆发式发展后，“跨过银联直连银行”“超大规模备付金风险”被监管关注，第三方支付开始进入严监管阶段，监管推出“非银行支付机构网络支付清算平台（网联平台）”，并于 2019 年实现第三方支付全面接入网联、备付金集中存管。
征信技术	1997 年，央行筹建银行信贷登记咨询系统，企业征信技术起步；1999 年，上海资信有限公司开始个人征信试点，个人征信技术起步。
	2004 年，《建设企业和个人征信体系总体方案专题报告》发布，征信业建设顶层设计完成。
	2005 年，全国集中统一的企业信用信息基础数据库建成；2006 年，个人信用信息基础数据库正式运行，同年，中国人民银行征信中心成立，企业信用信息基础数据库、个人信用信息基础数据库共同构成金融信用信息基础数据库（“一代”征信系统）。
	2013-2017 年，监管进行了个人征信民营试点，但最终宣布八家试点全不合格；同期，监管还进行了企业征信机构备案，总数最高到 200 余家。
	2018 年开始，个人征信业务重归监管，目前仅有 2 家持牌个人征信机构：百行征信（2018）、朴道征信（2020）；同期，企业征信机构备案也处于半封闭状态，新获备案的企业屈指可数。
	2020 年 1 月，二代征信系统上线，丰富了基本信息和信贷信息内容、改进了信息展示形式、提升了信息更新效率、强化了系统安全防护能力；同期，随着数据安全和合规的监管加码，个人征信机构、企业征信机构的监管政策也进入变革期。
其他金融科技	20 世纪 90 年代起，招行、工行便开始了虚拟银行、现代化银行系统的金融业务电子化之路。
	进入 2010 年，银行、保险、证券等金融机构与支付宝等互联网机构结合，开启了金融渠道网络化时代；这一时期，P2P 的兴起、乱象、清理之路，为我们理解金融科技发展和监管演进的关系提供了很好的样本。
	近期，随着人工智能、大数据、云计算、物联网等科技手段应用于金融产品创新、经营方式改变、业务流程优化，金融科技已从支撑业务向引领业务方向发展，金融数据的价值将

	更加凸显。也是在这一阶段，监管开始从金融信息安全、金融消费者保护、征信合规监管、App 违法违规治理等多方面对金融科技加强数据合规监管。2017 年，中国人民银行金融科技（FinTech）委员会成立，职责包括金融科技发展战略规划与政策指引、建立健全适合我国国情的金融科技创新管理机制、强化监管科技（RegTech）应用实践。2020 年 3 月金融标准化技术委员会发布《个人金融信息保护技术规范》、2020 年 9 月央行《金融消费者权益保护实施办法》通过，标志着央行以个人金融数据为首发阵地拉开了金融数据治理与监管落地的序幕。

2 中国金融科技数据合规未来监管趋势及应对策略分析

纵观中国金融科技的发展和监管史，**监管层对金融科技创新是持开放、鼓励的态度，愿意给新技术、新业务发展试错的空间**，但同时，**对于行业发展乱象、金融风险过分集聚也毫不手软**。我们认为，**未来金融科技数据合规监管的趋势将包括以下特点:**

(1)**穿透监管，**经营资质将成为重金融属性金融科技机构数据合规的压舱石。机构如果不仅开发、输出金融科技，还利用相关技术向客户直接提供金融性质服务，比如支付、征信、信贷等，那么持有相应经营资质则是数据合规的基本前提，没有相应经营资质，即便在技术、制度、运营方面全面达到了其他数据安全要求，也仍是非合规经营。

(2)**审慎监管，**善用技术、良好行业实践将成为细分行业可持续发展的数据合规路标。网贷行业以技术促进融资效率的初衷并不坏，但后期平台违规自融、买卖或违规使用客户数据、高杠杆对接金融市场等一系列坏操作，最终导致了行业的整体清理。第三方支付行业整体将技术用于促进商业发展，集聚的风险尚可化解，最后得以规范整顿后持续发展。两个行业监管的前车之鉴，明确传达了细分行业是否能够持续发展需要大部分参与者的良

好行业实践。

(3)**监管科技，**尊重、拥抱监管将是金融科技机构的数据合规路径。从中国金融科技的发展史可以看出，金融科技基本运行体制变革(联行清算制度)、基础设施建设重大飞跃(CNAPS 一代、二代，征信系统，银联、网联）均是监管层主导下发生的，市场主体的金融科技大繁荣均得益于此。市场主体需对中国监管层在金融科技方面的了解度、前瞻性、管理思路有正确的认识和充分的尊重。在监管过程中，监管层对于某一行业暂时的未监管，有可能是在给予行业自由发展的空间，也有可能是监管紧迫度暂时靠后，但当监管风向已经吹向自己时，拥抱监管、主动合规将是明智的路径选择。

(4)**双线监管，**在遵守《网络安全法》《数据安全法》《个人信息保护法》等通用法律法规的同时，金融数据处理者还需要特别关注金融监管机构关于金融数据特别是个人金融信息处理的合规要求。在此种监管背景下，金融行业基于存款实名制等强制性义务收集的个人金融信息，将成为一种“沉默数据”；金融科技企业在处理金融数据时，需要通过充分分析数据性质、改良数据授权链等多种方式，激活沉默数据、盘活数据资产、拥抱大数据时代，面对新的挑战。

（二）金融科技行业数据合规要点

1 取得相关经营资质

(1)金融类许可或备案，除了金融许可证外，常见的还有支付

许可、个人征信许可、企业征信备案、小贷许可、信用评级备案等;

(2)电信类许可，常见的有 ICP 许可、EDI 许可等。

2 安全等级保护和关键信息基础设施认定

对于有信息系统运行的金融科技机构而言，合理地进行安全等级保护备案、及时地确定是否属于关键信息基础设施，既是数据合规义务，也是数据合规工作正确开展的基础。

3 建立数据合规制度和运行管理体制

金融科技机构可以从制度制定、人员配备、体制运行等方面建立适合业务实际的数据合规体系，以做到数据合规有人管、有制度保障、有体系运行。

4 数据资产管理

(1)**数据分类分级。**金融机构已经有了明确的数据分类分级标准，其他金融科技机构可以参照标准对自己的数据资产进行分类分级，既方便确定合适的数据安全策略，也方便与各类金融机构合作过程中对于数据对接和通过合作机构准入的数据合规审查。

(2)**数据跨境。**现有监管对金融个人信息跨境有严格的前提条件，包括业务必要、客户明示同意、境外接收方为必要关联机构、开展安全评估、符合监管规定、境外机构数据安全保护能力达标、有措施确保境外机构的保密/删除、案件协查义务等。由于业务特性，金融科技机构及其处理的数据很容易进入关键信息基础设施

运营者、重要数据的范围，随着《数据安全法》《个人信息保护法》的正式发布与陆续施行，金融科技机构在处理各类数据跨境时，均应当关注相关安全评估、备案或批准要求。

(3)**个人信息、儿童信息保护。**当前立法和监管政策对个人信息、儿童信息有更为严格和特殊的保护要求，金融科技机构在处理相关信息时应注意遵守。另外，To B 金融科技机构需要注意，由于个人信息与企业信息中高管、董事、股东信息的界定或者说分类边界并不清晰，且企业征信业务管理的相关规范还在征求意见中并未定稿，在处理相关信息时要格外注意合规问题，不能简单的以 B 端业务为由带过具体问题的分析处理。

(4)**App 合规管理。**金融科技机构在打造自有 App 或输出 App 产品时，要注意遵守 App 治理的相关明文规范，避免出现明确列举的 App 违法违规情形。此外，对于小程序、H5、web 端产品，目前的监管趋势也是参照适用、逐步纳入，建议与 App 产品统一标准、从严管理。

（三）金融科技行业数据合规治理方案

1 内部治理要点

数据合规在法律层面、技术层面、运营管理层面均面临不同的挑战和难点，需要自上而下的有效协同，仅仅作为单一主体（DPO、CDO 或 CCO 等）或部门（法律合规部、IT 运维部门或数据合规部等）的责任很难达到机构的共同完善和整体合规。因此，**建议金融科技机构建设决策层牵头、数据合规或类似部门执**

行、全员参与的全方位、跨部门的数据协同管理体系：

(1)**顶层支持。**数据合规负责人应具有足够高的层级和管理权限，以保障和推动机构整体对数据合规问题自上而下的严肃、积极对待。

(2)**事前、事中、事后合规落地。**数据合规部门事前可从数据合规培训、数据合规文化建设等方面加强全体员工的数据合规意识；事中可在业务前期即参与产品创新、业务流程设计，减少事后纠错带来的内部抵触、成本浪费；关注事后排查，定期抽检，确认既定措施是否有效落实或是否存在技术故障导致合规瑕疵。

(3)**业务协同。**金融科技机构在展业过程中，尤其是项目初期，经常难以在取得“明确具体”的授权场景下与合作方交互数据，数据合规部门应和业务部门、技术部门协同合作，建立合理的数据处理机制，保障合规底线与数据可用性。

(4)**物质保障。**数据合规的落地需要资金、技术、人员等多方面的支持，金融科技机构需给予合理的保障。

2 外部治理要点

金融科技机构数据合规治理除了做好自身内部建设外，外部建设亦很重要，主要包括**监管、交易方、第三方机构**三个方面。

(1)**拥抱监管、有效合规。**如前所述，拥抱监管将是金融科技机构的数据合规路径。在拥抱监管的同时，更为重要的是在监管框架下进行有效的合规建设，既不能不满足监管要求，也要避免用力过猛。比如在等保认定方面，要结合自身系统和业务的实际情况，合理认定等保级别，认定级别过低，将造成企业在网安层

面的主体义务履行不合规，而超越实际情况拔高等保级别，则不仅会承担过高的等保义务，在等保与 CIIO 认定标准存在一定相似性的情况下，企业还可能需要承担更高的 CIIO 数据合规义务。

(2)**交易方合规管控。**数据合规需从取得到流转全流程均尽审慎义务，数据流转过程中应注意协议层面各方的责任分配，要求参与方均应尽到自身合规义务。不过，业务场景中常难以核查数据提供方或数据接收方授权落实情况，此时建议在不影响客户体验的情况下，尽量在自身平台建立完整的授权结构，避免合作方不合规导致自身风险。

(3)**有效利用第三方机构。**数据合规的规制、评测等存在大量复杂的专业问题，这些问题全凭机构自身的力量去解决，既不现实也不经济，有效利用律师事务所、合规事务所、评测机构、科研院所等专业力量，往往可以更高效的解决企业遇到的实际问题。

（四）金融科技行业数据合规法律法规焦点问题

1 个人征信数据“断直连”对金融科技市场侧的影响

今年 7 月，央行征信管理局要求平台、金融机构就个人信息全面“断直连”，即过渡期后平台不得将个人信息直接提交金融机构，而要通过“平台-征信机构-金融机构”的路径提交。考虑到目前个人征信机构仅有两家，其监管路径和对后续市场格局的影响，将与当年第三方支付机构断直连十分相似。

目前，业界大体有两个应对路径，一是寻找征信机构合作，一是通过个人直传（比如 H5 直跳银行界面）。前者对现有市场格

局和交易结构影响较大，对科技平台的科技和数据实力要求更高；后者则面临客户体验较差、再次被监管禁止等风险。相比较，前者更为长远。

需要注意的是，本次断直连仅涉及个人信息，主要针对消费金融，暂不涉及企业征信信息。但考虑到《征信业务管理办法》正在征求意见，其对企业征信信息、企业征信业务的范围作了较大范围的扩充，一旦通过，企业征信断直连亦非不可能。建议B端机构早做打算，尽早研究征信机构合作业务模式，或者依业务情况申请企业征信备案。

2 网络安全审查办法修订对金融科技资本侧的影响

《网络安全审查办法》修订特别增加了超百万用户的运营者在国外上市需网络安全审查的规定，且近期亦有消息指证监会拟将所有红筹VIE架构纳入监管。如果上述措施落地，金融科技企业美国上市之路将难度大增。

针对此项变化，业界普遍的看法是香港上市是备选答案之一，但是，考虑到港股上市条件较美股严格，仍会有部分企业既难以在美国上市又不能达到港股上市要求，相关企业仍需尽早规划融资路径。今年8月初，港交所前行政总裁李小加创办的连接中国小微企业和全球资本的投资平台“滴灌通”正式启动，拟建立以公司现金流或收益权为标的的交易市场，也许可以期待这种无需改变股权结构、无需搭建 VIE 架构的全新融资模式能为金融科技创业企业的境外融资打开一个新的大门。

二、智能汽车行业数据合规

自 2020 年 2 月国家发展改革委、中央网信办、工业和信息化部等多部委联合印发《智能汽车创新发展战略》以来，我国智能企业产业越来越受到国家和社会各界的重视和关注。智能汽车是汽车产业发展的战略方向，在汽车智能化、网联化发展给人们带来便利的同时，也会产生诸如未经授权的个人信息和重要数据采集、利用等数据问题，网络攻击、网络侵入等网络安全问题。因此，无论是智能汽车企业、广大消费者，还是国家有关监管部门，都越来越重视智能汽车行业的数据合规问题。

为帮助中国广大智能汽车企业系统了解相关法律法规等对智能汽车行业的数据合规要求，本文特对中国智能汽车企业的数据合规要点进行系统性梳理，希望能够对中国广大智能汽车企业以及整个智能汽车行业的数据合规工作有所帮助。

（一）智能汽车行业数据合规现状分析

1 智能汽车的特点

智能汽车是集环境感知、规划决策、多等级辅助驾驶等功能于一体，集中运用了计算机、现代传感、信息融合、通讯、人工智能及自动控制等技术的智能化交通车辆。目前对智能汽车的研究主要致力于提高汽车的安全性、舒适性，以及提供优良的人车交互界面。智能汽车已经成为世界车辆工程领域研究的热点和汽车工业增长的新动力，很多发达国家都将其纳入到各自重点发展

的智能交通系统当中。

相比传统的普通汽车，**智能汽车具有如下的特点:**

(1)驾乘功能的智能化。智能汽车最大的特点在于驾乘功能的智能化，在车载的传感器、摄像头等硬件及相关软件的支撑下，汽车具有了诸多智能化的功能，如：辅助驾驶、自动驾驶、智能泊车、智能大灯、智能车门等功能。

(2)数据处理的海量化。智能汽车通过各种摄像头、传感器、芯片，实时收集各种车内外的信息，与传统汽车不同的是，智能汽车与人的行为以及出行环境的结合更为紧密，功能更为全面，因而需要收集的数据类型也更为丰富、数据量也更为巨大。实际上，智能汽车驾乘功能智能化和娱乐功能多样化的特点，也奠定了智能汽车的数据处理海量化的特点。而这其中的数据，既涉及个人信息，也可能涉及各种重要数据，因此智能汽车企业需要严格做好数据合规管理。

2 智能汽车涉及的数据类型

智能汽车行业涉及的海量数据主要包括两大类：一类是用户相关数据，另一类是车辆相关数据。

用户相关数据主要包括：用户主动提供的身份信息数据（如：姓名、证件类型及号码、年龄、性别、职业、工作单位、地址、宗教信仰、民族、国籍、电话号码等），使用车辆时产生的用户行为数据（如：驾驶及行车安全服务信息、生活服务信息、联系人信息、用户操作日志等），以及语音、人脸图像等数据。

车辆相关数据主要包括：车辆基本资料（如：车辆类型、品

牌、型号、底盘型号、发动机号、燃油种类、车牌号、发动机号、车辆识别代码等），车辆辅助或自动驾驶软硬件的数据，车辆外部数据，车载导航数据以及服务于自动驾驶的高精度地图定位数据。

在智能汽车的用户相关数据和车辆相关数据中，大量数据属于驾驶员等的个人信息，也有不少数据属于国家严格管控的重要数据。在对这些数据进行处理时，应当严格遵守国家相关法律法规及部门规章等的规定。

（二）智能汽车行业数据合规要点

基于上述的行业现状，结合中国智能汽车企业的数据处理实践，对中国智能汽车企业在面临的数据合规要点进行梳理发现，**中国智能汽车企业的数据合规问题主要来自以下几个方面：**

1 个人信息处理征得同意

根据《民法典》的规定，对于智能汽车企业而言，除法律、行政法规另有规定外，在处理驾驶员、乘客等的个人信息前应当征得该自然人或其监护人的同意。

根据《最高人民法院关于审理使用人脸识别技术处理个人信息相关民事案件适用法律若干问题的规定》第二条，对于智能汽车企业而言，在处理驾驶员、乘客等的人脸信息前，除了按照法律、行政法规的规定征得自然人或者其监护人的书面同意的情形外，应当征得该自然人或者其监护人的单独同意。

其中，“单独同意”特别强调了“单独”，即对特定的个人信

息处理行为及其规则，个人能够独立于其他个人信息处理行为及规则，做出自主的意思表示。单独同意，目的在于对特定个人信息处理行为和特定个人信息类型提供增强式保护，让个人更加充分地参与到个人信息处理的决策之中。

智能汽车企业要处理海量的个人信息数据，如何保证数据处理满足征得同意的相关规定，也就成为了智能汽车企业在产品和业务设计过程中需要格外关注的问题。

此外，《汽车数据安全管理若干规定（征求意见稿）》等尚未生效的法律规范，对于个人信息的处理规定了更为严苛的条款，如：要求每次个人信息处理需要每次征得同意、仅对每次驾驶行为有效等。这些规定与常见的一次授权、长期有效的授权模式完全不同，导致用户体验差。智能汽车企业也需要在产品设计时考虑如何应对类似的实操层面的合规困境。

2 个人信息及数据的安全

智能汽车提供的多元的功能、服务和界面（例如网页、RFID、Wi-Fi）增加了攻击面，因此增加了潜在网络漏洞的数量，这些漏洞可能会危及个人信息和重要数据的安全。与多数物联网设备不同，智能汽车是关键系统，安全漏洞可能会危及驾驶员、乘客和车辆周围人的生命财产安全。因此，做好个人信息和重要数据的信息安全保护，解决黑客试图利用联网车辆漏洞的风险尤为重要。

《民法典》第一千零三十八条第 2 款也明确规定，信息处理者应当采取技术措施和其他必要措施，确保其收集、存储的个人信息安全，防止信息泄露、篡改、丢失。由此可见，对于智能汽

车企业而言，个人信息和重要数据的信息安全保护，是其数据合规的重点工作之一。

3 数据的存储、出境合规

《网络安全法》第三十七条规定，关键信息基础设施的运营者在中华人民共和国境内运营中收集和产生的个人信息和重要数据应当在境内存储。因业务需要，确需向境外提供的，应当按照国家网信部门会同国务院有关部门制定的办法进行安全评估；法律、行政法规另有规定的，依照其规定。

对于智能汽车企业而言，智能汽车所处的车联网涉及海量的个人信息和重要数据，智能汽车企业很可能被认定为关键信息基础设置的运营者。因此，智能汽车企业在中国境内运营中收集和产生的个人信息和重要数据应当在境内存储，因业务需要，确需向境外提供的，应当按照国家网信部门会同国务院有关部门制定的办法进行安全评估。由于很多智能汽车企业特别是外资智能汽车企业涉及跨国运营，很可能在实际操作中将个人信息和重要数据存储在了境外，或者在未经审批的情况下将相关数据向境外提供。这将使得这些智能汽车企业面临严重的数据合规风险。

例如，据国家互联网信息办公室 2021 年 7 月 2 日消息，为防范国家数据安全风险，维护国家安全，保障公共利益，依据《中华人民共和国国家安全法》《中华人民共和国网络安全法》，网络安全审查办公室按照《网络安全审查办法》，对“滴滴出行”实施网络安全审查。为配合网络安全审查工作，防范风险扩大，审查期间“滴滴出行”停止新用户注册。滴滴虽然并非智能汽车企业，

但在很大程度上智能汽车企业面临着与共享汽车出行企业类似的数据合规特别是存储和跨境问题。

4 第三方服务的数据合规

第三方服务问题，在智能汽车中凸显。第三方服务是指在智能汽车上为汽车用户提供服务的除智能汽车企业外的其他模块、产品或服务提供商等第三方提供的服务。第三方服务的内容通常包括：音频、视频服务，导航服务，自动驾驶服务，广告及信息推服务等。对于智能汽车的需要通过第三方服务商为用户提供的服务，通常就会涉及到第三方服务商的数据合规法律问题。

对于相关的第三方服务，到底应当由谁（是智能汽车企业，还是第三方服务商）来承担数据合规责任？对于相关服务是否显示第三方服务商的不同情况，数据合规责任的承担主体是否有所不同？这些都是智能汽车厂商正在面临但当前相关法律又无明确规定的问题。

5 汽车地理信息数据合规

智能汽车的常见功能之一是外部摄像头的影像获取功能，通过外部摄像头，智能汽车的运营者可以获取汽车周围的环境信息、道路标示图像信息等信息。这些图像信息与地理信息、地图位置信息的结合，可以形成更为精准的地图信息，为智能汽车的辅助驾驶、自动驾驶等功能提供更高质量的地图引导。

根据我国《测绘法》第二条："本法所称测绘，是指对自然地理要素或者地表人工设施的形状、大小、空间位置及其属性等进行测定、采集、表述，以及对获取的数据、信息、成果进行处理

和提供的活动。”智能汽车在拥有高精定位技术的情况下，采集自然地理信息的行为很大程度上会落入《测绘法》的规制范畴下，由此可能引发如下问题:

a) 测绘行为在我国实行的是资质准入，需要持有测绘资质才能够进行测绘行为。

b) 测绘地理信息属于外资禁入的负面清单，外资的智能汽车企业可能无法从事相关业务。

（三）智能汽车行业数据合规治理方案

智能汽车的数据合规应当覆盖智能汽车相关数据的全生命周期，覆盖数据的收集、存储、使用、内部管理、对外提供等全部环节。下文将根据中国有关法律法规的基本要求，结合数据全生命周期管理的要求，为智能企业的数据合规工作的开展提供便于实操的要点性建议。

1 严格落实数据处理授权合规

数据对于智能汽车行业而言是不可或缺的重要基础设施。为保证自身业务的安全性，智能汽车企业在数据合规方面首先要解决的就是数据处理（包括但不限于收集、存储、使用、加工、传输、提供、公开等）的授权问题。

在智能汽车的研发过程中，应当科学规划数据处理的授权合规问题，包括但不限于：在处理驾驶员、乘客等的个人信息前，应当通过 App 弹窗等形式征得该自然人或其监护人的同意。而对于人脸信息，则应当通过 App 弹窗等形式征得该自然人或者

其监护人的单独同意。

对于客观上无法有效获得用户同意的业务形态，建议智能汽车企业暂缓开通相关功能，已经开通的，建议考虑下线相关功能，以防控数据合规风险。例如：某些智能汽车试图通过车内摄像头采集乘客的人脸信息以用于某些业务，但是，由于乘客自身通常没有智能汽车管理相关的 App，无法明确单独同意智能汽车企业采集其人脸信息。对于这种情况，如果智能汽车企业擅自采集智能汽车内的乘客人脸信息，将给自身带来严重的数据合规风险。

2 积极采取数据安全管理措施

对于智能汽车企业而言，个人信息和重要数据的信息安全管理，是其数据合规的重点工作之一。**对于智能汽车相关的数据安全措施，应当主要包括如下内容：**

a）**建立数据管理制度。**应当建立健全企业的数据安全管理制度，使得制度覆盖信息安全和数据管理全生命周期。

b）**设置数据管理机构。**企业应当设置专门的数据安全管理机构，例如企业信息安全部门，以从技术角度科学推进数据安全管理。

c）**采取数据存储、传输及访问权限安全措施。**数据应存储在中国境内的服务器；数据的存储和传输应当加密；此外，还应当严格设置数据访问权限及访问数据的范围；对于生物特征识别数据，原则上不存储和传输原始数据，可采取必要的脱敏措施。

此外，企业还应当建立信息安全事件响应机制，设置应对信

息安全事件应急响应制度。

3 扎实推进数据对外提供合规

智能汽车企业在数据处理过程中，不可避免地要对外提供数据。数据对外提供主要包括数据委托处理、数据共享、数据转让、数据跨境传输等不同场景。

数据委托处理场景下，数据合规及安全责任主要由控制者承担，受托方需严格按照与控制者的协议约定，在控制者的指示下处理数据；数据共享场景下，双方互为数据控制者并共同对数据主体承担责任，双方需在合作协议中理清彼此的数据合规义务。对于智能汽车相关数据的跨境传输，按照《网络安全法》规定，涉及个人信息及重要数据的，需在完成安全评估并报相关机构备案后，方可跨境传输。

无论是何种场景，建议智能汽车企业应在数据对外提供前，充分审查合作方的数据安全管理能力，并与合作方通过协议等形式，要求合作方作为数据接收方应在约定目的范围内使用数据，并承担保密、信息安全保障等义务。

4 深入管控第三方的数据合规

对于智能汽车企业而言，在汽车的制造过程中，不可避免地会用到大量的第三方服务，如：音频、视频服务，导航服务，自动驾驶服务，广告及信息推服务等。相应地，第三方的数据合规，成为了智能汽车企业不得不面对的棘手问题。

智能汽车企业应当对第三方服务的数据合规问题进行严格管控。**相关管控工作应当至少包括如下两个方面的内容：一个方**

面是，应当通过合同等形式明确约定应用于智能汽车中的第三方服务的数据合规责任主体。从成本控制、利于管理等维度考虑，建议争取约定为由第三方服务商承担相应的数据合规责任。**另一个方面是**，应当要求第三方服务商建立完善的数据合规管理制度。只有切实建立起数据合规管理制度，第三方服务商才有可能将相关服务的数据合规工作落到实处。

5 及时跟进数据立法执法动态

鉴于我国目前网络安全及数据合规领域立法不断发展，执法活动呈现频密化趋势，建议智能汽车企业及时关注中国国内的立法、执法最新趋势，尤其是国家顶层立法及行业主管部门制定的专项法规要求，与时俱进地调整企业内部数据合规管理制度，防范由于数据合规管理不到位而给企业带来的各种负面影响。例如，对于智能汽车采集自然地理信息的行为是否受《测绘法》等现行法规制的问题，智能汽车企业就应当实时关注国家相关的立法和执法情况，以相应制度进行应对。并且，智能汽车企业还可以考虑通过适当的方式，将自身的立法建议反馈给有关主管部门，以争取使得相关立法向有利于产业的方向发展。

此外，智能汽车企业应重视对本行业发生的数据合规相关的案例、投诉、处罚等进行跟踪，并及时相应针对自身业务存在的相关问题采取弥补、优化等管理措施，从而提升自身的数据合规管理水平。

（四）智能汽车行业数据合规法律法规焦点问题

开展智能汽车企业数据合规工作，首先要了解智能汽车企业所在国家以及业务所涉及的国家的数据合规相关法律法规。本文法律法规为广义，包括法律、行政法规、司法解释、部门规章等。

截至目前，中国已生效的与智能汽车企业的数据合规相关的法律法规主要包括:《中华人民共和国民法典》《网络安全法》《数据安全法》（2021 年 9 月 1 日起施行）、《个人信息保护法》（2021 年 11 月 1 日起施行）、《刑法修正案（九）》《最高人民法院最高人民检察院关于办理侵犯公民个人信息刑事案件适用法律若干问题的解释》《最高人民法院关于审理使用人脸识别技术处理个人信息相关民事案件适用法律若干问题的规定》《电信和互联网用户个人信息保护规定》《全国人大常委会关于加强网络信息保护的决定》《GB/T 35273-2020 信息安全技术个人信息安全规范》等。

此外，对于智能汽车相关的法律法规，在欧盟主要包括《通用数据保护条例》《联网车辆和交通相关应用程序中处理个人数据的指南》等法律法规，在美国主要包括《加州消费者隐私保护法案》《加州隐私权保护法案》等法律法规。

对于在中国境内从事数据处理的智能汽车企业而言，首先，应当遵守《民法典》第一千零三十四条至第一千零三十八条关于个人信息的规定，此规定给中国境内的数据合规特别是个人信息保护提供了最本源的法律依据。其次，还应当遵守《网络安全法》、《数据安全法》等法律，工信部以及网信办等部门的相关部门规章，以及最高人民法院和最高人民检察院的相关司法解释。然后，

还应当参考信安标委《GB/T 35273-2020 信息安全技术个人信息安全规范》等国家标准。此外，如果该智能汽车企业还涉及域外数据合规问题，还需要遵守相应国家的法律法规。

三、在线教育行业数据合规

随着信息技术产业革命的发展，新一代信息技术不断涌现，正影响着各行各业变革和人们的日常生活。截至 2020 年 12 月，我国在线教育用户规模达 3.42 亿，占网民整体的 34.6%; 手机在线教育用户规模达 3.41 亿，占手机网民的 34.6%。下半年，随着疫情防控取得积极进展，大中小学基本恢复正常的教学秩序，在线教育用户规模回落，但较疫情之前（2019 年 6 月）仍增长了 1.09 亿，行业发展态势良好。企业作为最大的受益主体，对相关数据合规的审查和数据风险防控就显得尤为重要。

（一）在线教育行业数据合规现状分析

据著名咨询机构 IDC 预测，2025 年全球数据量将高达 175ZB。其中，中国数据量增速最为迅猛，预计 2025 年将增至 48.6ZB，占全球数据圈的 27.8％，平均每年的增长速度比全球快 3％,中国将成为全球最大的数据圈（数据圈指被创建、采集或是复制的数据集合）。数字经济带来了前所未有的红利，吸引着更多的投资者及创业者的加入，但在纷杂的市场竞争中，也面临着许多法律问题，从投资者层面来说，从事在线教育行业的企业良莠不齐，需要对投资的企业开展风险防控。去年 7 月起，教育部等六部门

就已开始大力整顿线上培训机构。13.6 万家在线教育机构在去年注销，意味着在线教育野蛮生长时代的结束。今年 1 月 18 日，中纪委网站发布《资本漩涡下的在线教育》一文，直指在线教育存在虚假宣传、资金链断裂、盲目扩张、资本助推致内耗严重等一系列问题。5 月，北京市市场监管局对“猿辅导”和“作业帮”处以警告并顶格罚款 250 万元，引发在线教育行业“裁员潮”。

为此，“双减”意见中出台了几项关键性举措。

第一，学科类培训机构将统一登记为非营利性机构。其收费纳入政府指导价管理，由各地政府科学合理确定计价办法，明确收费标准。

第二，严禁资本化运作。学科类培训机构一律不得上市融资，严禁资本化运作，上市公司不得通过股票市场融资投资，不得通过发行股份或支付现金等方式购买有关资产。已违规的，要进行清理整治。

“非营利性”“严禁资本化运作”这几个关键词，让教育培训行业今后再难成为资本捞钱的工具。“双减”意见出台后，已经连跌了几个月的教育股再次全线大跌。拥有数万名员工的教育机构，既然未来无法再盈利，面临的无非是关停裁员或转型两条出路。在教培企业转型的浪潮下，企业的数据合规风险防控愈加重要。

1 在线教育数据要素的特点

（1）**依托互联网和大数据，具有多种媒体学习资源和资源共享渠道，信息数据更新速度快。**“教育+互联网”衍生下的在线

教育行业各类新模式、新技术、新业态纷纷涌现。

（2）**非 K12 的职业教育增势迅猛。**2021 上半年，在线教育行业乱象频发，整顿力度持续加大；K12 教育用户规模略有回落。职业教育增势迅猛，用户规模翻一番同比增长 120%；中国在线职业教育市场发展空间巨大，市场规模稳定增长，预计 2021 年，职业教育市场规模将超 3000 亿元；体制内就业的吸引力不断上升，考公成为“风潮”，考公类培训 App 规模增长；短视频+职业教育前景良好，未来或将成为在线职业教育的标配。

教育部于 6 月 15 日宣布成立校外教育培训监管司，承担面向中小学生（含幼儿园儿童）的校外教育培训管理工作等，推动“双减”工作落地见效。K12 教育企业在教育部双减新规的严管下面临着教育模式创新和转型升级的考验。互相共存，彼此制约，安全与发展成为在线教育数据要素的新的挑战。

（二）在线教育行业案例及数据合规要点

1 关于个人信息保护

在线教育所涉及的个人信息可分为以下四类：注册信息，即用户在首次使用在线教育平台或 App 时录入的信息；在线教学信息，是指在线教育平台发布的信息以及用户在平台上的相关使用和存储信息；系统安全及客服信息，是指平台系统运营方面的有关信息及客服的联络和服务信息；其他功能所涉信息等等。

最高人民检察院发布 11 件检察机关个人信息保护公益诉讼典型案例之四：江苏省无锡市人民检察院督促保护学生个人信息

行政公益诉讼案中，2016 年 7 月，甲培训机构总经理孟某购买中小学在校学生个人信息 23 万余条，并将上述信息用于其培训机构电话招生。2018 年 7 月，孟某向王某出售、向乙培训机构总经理方某提供上述信息。甲乙两培训机构均无办学许可证，而上述信息多为格式统一、内容全面、精确度高的整个学校或整个班级的信息，内容包括学校、学生姓名、入学年份、班级、学号、邮寄地址及父母姓名、联系方式等，给广大学生个人信息保护带来严重安全隐患。校外培训机构非法获取学生个人信息用于电话招生、侵害学生合法权益。

根据刑法第二百五十三条侵犯公民个人信息罪，“违反国家有关规定，向他人出售或者提供公民个人信息，情节严重的，处三年以下有期徒刑或者拘役，并处或者单处罚金；情节特别严重的，处三年以上七年以下有期徒刑，并处罚金”，企业窃取个人信息或未经允许向第三方买卖个人信息都构成侵犯公民个人信息罪。

合规要点：

1）制定内部管理制度和操作规程，对个人信息实行分类管理；

2）采取相应的加密、去标识化等安全技术措施；

3）合理确定个人信息处理的操作权限，并定期对从业人员进行安全教育和培训；

4）制定并组织实施个人信息安全事件应急预案；

5）企业非经批准不得将个人信息提供给境外的司法/执法机构。

2 关于对未成年人个人信息的特别保护与隐私政策

关于2018年，Facebook旗下的聊天工具“Messenger少儿版”被指未遵守美国保护青少年隐私的法律法规 COPPA，在家长未授权条件下，采集不到十岁的少儿隐私信息。后 Facebook 又爆发了泄露5000万用户隐私信息的事件，可能面临欧盟16亿美元的罚款。

2020年1月以来，“App个人信息举报平台”关于疫情期间在线教育类收集个人信息被举报的数量占比超过了80%，30%左右的App 没有公开隐私政策等收集使用个人信息的规则，另有15%左右的App虽提供了隐私政策，但是属于格式文本，没有详细说明收集个人信息的目的、方式、范围。这导致用户不知个人信息去向，而未经用户允许向第三方提供其个人信息属于侵权。

合规要点：

1）与家长和其监护的儿童的权益（可能）密切相关的重要条款，采用加粗字体来特别提醒；

2）在收集到儿童个人信息后，通过技术手段及时对数据进行匿名化处理；

3）若企业对于儿童的个人信息用于除政策列明之外的目的、范围或与使用于数据收集不一致的传输方式时，企业应当通知儿童监护人并取得监护人的同意；

4) 只共享必要的儿童个人信息，且受本隐私政策中所声明目的的约束；

5) 服务中的部分功能可能需要儿童在设备中开启特定的访问权限（例如摄像头、相册、麦克风及或日历），以实现这些权限所涉及信息的收集和使用，当儿童和监护人需要关闭该功能时，大多数移动设备都会支持该项需求。

3 关于数据处理过程中不同类别的数据处理关系

单独收集控制，是指在线教育企业自己收集控制用户个人信息，没有第三方参与，仅仅是用户与企业的双向联系，例如各大网校的在线教育平台。

委托收集控制，是指在线教育企业通过第三方平台收集控制用户个人信息，第三方成为企业和用户之间的媒介，典型的是不同企业或个人之间的数据买卖和数据共享。

例如（2020）皖 0504 刑初 123 号《孙成诈骗罪》一案中，被告人孙成利用其皖江职业教育中心学校在编教师、六安市金寨职业教育中心学校支教教师、借调马鞍山市教育局工作的身份，获得在校学生等人员信任，为填补 2016 年前擅自进行提升学历招生，并用报名费进行投资理财欠下的高额资金缺口，在皖江学校、金寨学校进入相关班级，以帮助他人完成学历提升为由，夸大或隐瞒相关招生信息，以高升专 6400 元/人、专升本 7800 元/人的自定价格向报名学生收费，另孙成随机向报名学生额外收取 200 元/人的报名考试费，诈骗数额总计人民币 1251000 元。

（2015）万刑初字第00062号张初兵、原勇刚、朱鹏欧、谭正求伪造、变造、买卖国家机关公文、证件、印章罪一案中，2014年3月以来，被告人谭正求以张贴小广告的方式联系购买假证、假印章的客户并收集其信息，或由邓某、王某（已判刑）以张贴小广告的方式将收集到的客户信息通过QQ邮箱发送给被告人谭正求。获取客户信息后，被告人谭正求交由被告人张初兵或被告人原勇刚伪造，伪造好后，被告人谭正求予以出售或交由邓某、王某出售，几人共同从中牟利。截止案发，被告人谭正求通过被告人张初兵伪造并出售各类证件50余份，通过被告人原勇刚伪造并出售各类印章7枚、身份证4张，获利8000余元。

合规要点：

1) 受托方应当按照约定处理个人信息，不得超出约定的处理目的、处理方式等处理个人信息；
2) 委托合同不生效、无效、被撤销或者终止的，受托方应当将个人信息返还个人信息处理者或者予以删除，不得保留；
3) 未经个人信息处理者同意，受托方不得转委托他人处理个人信息。

4 关于网络和数据安全技术

其一是设备本身存在的漏洞。不管是计算机软硬件还是网络系统，都是由人为编程而来，背后难免会出现缺陷或漏洞，而这些漏洞则为网络攻击提供了缝隙，让网络安全暴露在外。

其二是网络边界的被打破。如今网络的普及和发展，正在让

网络世界与物流世界边界瓦解，联网成为趋势，但同时也成为问题滋生的风险。

其三是数据流通的加快。伴随着网络边界被打破，网联化趋势愈发加剧，数据生产、流通和共享也是越来越频繁，导致数据泄露的风险不断加大。

例如，（2017）渝0231刑初425号刘川谢福祥侵犯公民个人信息罪一案中，2017年4月，被告人谢福祥、刘川共同成立了重庆云库广告有限公司，招聘了史某、董某、王某等业务员进行公民个人信息的买卖，具体由业务员负责在各个招商网站上搜索需要公民个人信息的招商客户并进行联系，再由谢福祥、刘川通过招商网站收集或者通过 QQ 群购买包含公民联系方式等数据的公民个人信息后，借助QQ或者微信出售给联系好的客户。期间，二人除平摊公司的日常开销外，分别管理业务员和买卖公民个人信息。其中，被告人谢福祥在与被告人刘川共同成立公司以前，还单独向他人多次出售公民个人信息。2017年2月至7月期间，被告人谢福祥、刘川通过出售公民个人信息分别获款 61812 元、25940 元。根据《最高人民法院、最高人民检察院关于办理侵犯公民个人信息刑事案件适用法律若干问题的解释》第五条第一款第（七）项“违法所得五千元以上的”、第二款第（一）项“数量或者数额达到前款第三项至第八项规定标准十倍以上的”，构成侵犯公民个人信息罪。

其四是各种新技术的应用。新一轮科技革命的到来，推动了人工智能、5G、生物识别、物联网等一众新技术的应用，而这些

新技术不但本身可能存在安全风险，与此同时还可能成为网络犯罪的帮凶。

其五是内鬼的层出不穷。相关数据显示，当前超过85%的网络安全威胁来自于内部，其危害程度远远超过黑客与病毒攻击。企业内部员工也成为数据风险的推动者之一。

（三）在线教育行业数据合规治理方案

在线教育平台运营者需从技术、管理层面同时发力提升信息泄露防护能力、增强数据安全保护思想意识。

1 提升数据安全保护技术能力

运营重要信息系统，掌握大量教育数据的机构（如教育主管部门、重点高校、教育领域协会组织、国家教育基础设施与电子资源库、其他教育数据中心等）可提升以数据安全为核心的防护技术能力，保证教育信息安全，避免数据泄露事件频发。一是针对运营的海量教育数据建立数据管理平台，对数据进行统一管理；二是通过高强度、安全可靠的加密手段为重要信息提供有力保护，保证敏感关键信息无论何时何地都是加密状态，可信环境内，加密文档可正常使用，在非可信环境内无法访问加密文档；三是建立全面的信息泄露溯源追责机制，通过防泄露技术进行技术防护，通过完整的文档、操作审计发现风险触发点，做到事中研判防御，事后溯源追责。

同时，广泛调研国内大数据关键技术发展情况，实现教育领域大数据安全技术可控是保护数据安全的重要手段之一。在教育

CSTC中国评测

行业信息系统的建设、运营、大数据中心搭建、教育机构门户运维等工程中支持国内研发的产品应用，为大数据关键技术发展提供更稳定安全的环境。

2 健全数据安全保护制度体系

针对教育行业个人信息保护工作不佳，数据泄露事件时有发生的情况，应当从立法、立标、树规、贯标等方面对信息安全技术防护体系进行管理上的补充，提升“三分靠技术，七分靠管理”的安全意识。

目前数据安全与个人信息保护相关法规已经出台，数据安全合规性需求将进一步加大。针对数据安全保护、信息泄露事件的监管将进入法制时代，基础法规的颁布需要行业领域内制定具体的标准规范进行贯彻，通过国家标准或行业标准对教育行业关键信息、敏感数据进行分类分级管理。可以用数据标签对收集数据、处理数据、存储数据、传输数据和销毁数据提供技术上和操作上的规范要求。对于关系到教育行业发展以及系统用户个人信息的重要数据，需严格控制其存储位置、传输和使用方式。

3 增强数据安全保护思想意识

在教育行业中的数据保护方面，尤其需要增强用户的网络信息安全意识。

一是针对受教育群体而言，他们是教育信息系统、在线教育平台、App、微服务等应用程序的前端用户，需要提升应用使用安全意识，形成安全习惯。

一是针对企业内部数据管理人员，他们是数据的管理者，同

时也是数据的守护者。在企业内部应大力开展数据安全保护意识活动，宣传安全意识，定期举办数据安全教育培训，制定管理人员操作数据的详细规定，定期评估内部人员操作数据行为是否规范。

（四）在线教育行业数据合规法律法规焦点问题

随着《数据安全法》《个人信息保护法》以及具体管理规定的不断出台，规定了国家及中央国家安全领导机构、各地区各部门各行业主管部门的监管职责，同时也明确了在线教育机构作为数据管理者应切实履行数据保护义务，要加强组织领导，明确数据安全责任部门和责任人，建立全生命周期的数据安全管理体系和机制，采取相应的技术措施开展风险监测和应急处置，加强重要数据安全风险评估和出境管理。

现行相关法律法规可以分为两个方面，一是根据新情况修改现行立法并细化相关解释，二是全面保护个人信息，填补新兴领域立法空白。

1《数据安全法》

第二十七条“开展数据处理活动应当依照法律、法规的规定，建立健全全流程数据安全管理制度，组织开展数据安全教育培训，采取相应的技术措施和其他必要措施，保障数据安全”，第三十条“重要数据的处理者应当按照规定对其数据处理活动定期开展风险评估，并向有关主管部门报送风险评估报告”，第三十二条“任何组织、个人收集数据，应当采取合法、正当的方式，不得

窃取或者以其他非法方式获取数据”。这说明在线教育机构应以合法合规的手段收集数据，并对数据处理活动依法依规开展数据安全管理与风险评估工作。

2《个人信息保护法》

第四条规定“个人信息是以电子或者其他方式记录的与已识别或者可识别的自然人有关的各种信息，不包括匿名化处理后的信息。个人信息的处理包括个人信息的收集、存储、使用、加工、传输、提供、公开等”，第九条“个人信息处理者应当对其个人信息处理活动负责，并采取必要措施保障所处理的个人信息的安全”。这说明在线教育机构应当在法律允许的范围内收集数据并对其收取的用户个人信息负责。

3《网络信息内容生态治理规定》

第二十一条规定，“网络信息内容服务使用者和网络信息内容生产者、网络信息内容服务平台不得利用网络和相关信息技术实施侮辱、诽谤、威胁、散布谣言以及侵犯他人隐私等违法行为，损害他人合法权益”。在线教育机构提供、使用、交流网络教育信息，必须明确依法规范和管理平台上的违法信息、防范和抵制不良信息传播，做好数据合规是在线教育企业必须承担的社会责任，也是法律责任。

四、电信和互联网行业领域数据合规

（一）电信和互联网行业数据合规现状分析

1 行业数据主要分类

(1) 基于行业特点划分

行业基础网络数据。主要指用户及企业在使用电信基础网络设施过程中所产生的基础数据，包括了个人及设备的标识数据、位置及行为的日志数据等，依据对电信基础网络的调研结果，可以将其主要划分为:

- 基础信息类数据
- 日志类数据
- 结果类数据
- 辅助类数据
- 管理类数据

行业基础业务数据。行业的数据资产结构主要与其开展的业务相关，目前较突出的是社交数据、电商数据、游戏数据、用户行为数据。其中:

- 社交数据主要包括关系链数据、用户间的互动数据、用户自己产生的图文和视频内容、用户的位置信息等;
- 游戏数据主要包括大型网游数据、网页游戏数据、手机游戏数据，及游戏活跃行为数据和付费行为数据;
- 电商数据主要包括商品浏览、搜索、点击、收藏、购买、物流等数据;
- 用户行为数据主要包括社交行为数据、访问浏览数据、搜索数据、消费数据等。

CSTC中国评测

(2)基于服务对象划分

用户数据。各系统和业务的用户所拥有和产生的数据，主要包括了用户身份相关数据、用户服务内容数据、用户服务衍生数据等。

- 用户身份数据主要包括了用户自然人身份标识和证明或网络虚拟身份标识、用户基本资料及私密资料等信息，以及用网络身份鉴权信息；
- 用户服务内容数据主要包括了对用户提供的电信和互联网服务的内容数据、联系人信息等资料数据；
- 用户服务衍生数据主要包括了服务订购数据、行为数据、位置数据、征信或违规数据等用户衍生数据以及用户设备信息等数据。

企业运营管理数据。系统运行和业务流程中，服务于企业自身经营的各类数据，主要包括企业管理数据、业务运营数据、网络运维数据、合作伙伴数据等。

- 企业管理数据主要包括企业内部管理数据，如发展战略及规划数据、财务数据、人事数据、对外合作数据及其他管理数据；
- 市场经营类数据，如经营分析类数据、经营考核类数据、资源部署数据、营销方案等；
- 企业公开披露和上报数据，主要指资本市场及主管部门要求公开或上报的数据；

- 业务运营数据主要包括资费信息及管理信息、渠道数据、客服数据、营销数据及日常运营产生的其他数据等;
- 网络运维数据主要包括密码及关联数据、资产资源类数据、支撑类数据等;
- 合作伙伴数据包括合作伙伴基础资料信息、合同协议、合作过程中产生的数据等。

2 行业数据安全总体形势

(1)事件影响范围不断扩大

电信和互联网行业是全球数字化进程的先驱。随着数字化进程的迅猛推进，数字技术已向行业全方位加速渗透、融合。数字化程度愈高，数据安全风险暴露面、攻击面越广，加之数据价值的提升，数据市场的驱动，数据利益相关方趋之若鹜，围绕网络攻击、数据窃取和数据交易形成的数据黑市已经成为大规模、有组织的犯罪集团，数据黑灰产猖獗，数据滥用及数据安全事件愈演愈烈。

2020 年 5 月 19 日，美国电信巨头 Verizon 公司发布 2020 年数据泄露调查报告(DBIR)。报告显示，81 个国家参与调研的数据泄露事件中，55%的泄露事件和有组织犯罪相关，外部攻击占 70%，企业内部攻击占 30%；58%涉及个人数据泄露，72%的受害者为大型企业。

从数据安全影响的对象来看，影响范围从最初的企业和个人逐步向整个行业及全社会蔓延。从发展的角度来看，首先，影响行业数据合理开放共享的意愿和积极性；其次，影响用户对行业

数据安全治理的信心，从而影响行业新技术新业务与实体经济的深度融合；再者，数据安全问题为数据跨境流通、数据驻留规管带来负面影响，甚至面临被动局面。

(2)风险危害程度日趋严重

首先，因行业数据价值巨大，一旦出现安全问题，会给企业声誉和经济造成损失。2020 年 2 月 23 日，某 SaaS 服务商因员工恶意破坏公司线上生产环境及数据，导致其相关系统崩溃，大量商家的线上生意停摆，直至 3 月 3 日才完成了全部的数据恢复上线。此次事件后果严重，其服务的 300 万家商户受到影响，在正式公告发出前 5 个工作日，服务商股价下跌超 22%，市值缩水超 30 亿港元。据 IBM《2019 年全球数据泄露成本报告》显示，过去 5 年数据泄露成本上升了 12%，平均成本已达到 392 万美元。恶意数据泄露会给企业带来平均 445 万美元的损失，比系统故障和人为错误等意外原因导致的数据泄露高出 100 多万美元。

其次，可能危害到用户的生命或财产安全。如个人信息泄露不只是隐私权被侵犯的问题，也可能被犯罪分子利用，进行违法犯罪活动，电信和互联网诈骗事件就是典型，也不乏与个人信息泄露相关的命案。

此外，各国非常重视大数据在国家安全领域的运用，随着各国的数据战略部署，数据治理逐步上升到国家战略层面，某些数据安全事件极有可能发展为影响社会秩序、政治稳定、国家安全的非常事件。

(3)安全治理难度持续升级

引发数据安全风险的风险源可能是机器故障、内部人员的恶意行为或失误操作，也可能是外部黑客的恶意攻击；而恶意攻击途径又有不同，包括采用恶意软件、安全漏洞、社会工程学等手段或多种手段的组合；发起数据安全攻击的动机也不尽相同，单纯的炫技、商业或经济利益、军事或政治利益等。这为数据安全风险的防范带来一定难度。

此外，随着行业网络形态不断演化，新技术新应用场景的日渐复杂，衍生出新的数据类型、数据生产方式、数据处理方式和终端形式等，引发了新一轮的数据安全事件爆发，而对于新型安全风险的研究和防范能力目前还有待提升，安全挑战不断加剧。

再者，数字化的加速推进促进了复杂网络中的数据流通，极大的模糊了传统数据安全的边界，使得行业基于边界或网元的防护体系不再能满足当前跨组织的数据流通安全风险管理、联动规范的接口管控、风险管控追踪等数据安全治理需求。多方面因素导致数据安全治理难度持续升级。

（二）电信和互联网行业数据合规要点

2019 年，工信部部署全国基础电信企业（含专业公司）、50 余家重点互联网企业及 400 余款 APP 运营者，结合重点业务类型和场景，依托互联网新技术新业务安全评估机制，对标《2019 年基础电信企业数据安全合规性评估要点》和《2019 年互联网企业数据安全合规性评估指引》，全面开展网络数据安全合规性评估，并将其作为重点工作内容纳入年度网络信息安全“双随机一公开”检查和基础电信企业网络与信息安全责任考核检查。在《关

于2020年电信和互联网行业网络数据安全管理工作的通知》中，明确了行业开展网络数据安全合规性评估工作的相关部署，同时布了《2020年电信和互联网企业网络数据安全合规性评估要点》。

《2021 年省级基础电信企业网络与信息安全工作考核要点与评分标准》中明确要求企业应按照《电信和互联网企业网络数据安全合规性评估要点》完成数据安全合规性评估，于数据安全公共服务平台（ds.cisms.cn）登记并更新评估完成情况，各项评估要点要求应于 11 月底前完成。对于处理大规模数据的业务，应开展新技术新业务安全评估，并形成评估报告，未按要求完成的，扣 10 分。《2021 年基础电信企业专业公司网络与信息安全工作考核要点与评分标准》中明确要求企业数据安全管理应按照《网络安全法》《电信和互联网用户个人信息保护规定》，落实行业网络数据安全管理重点工作任务，提升企业整体数据安全保护能力和水平。其中要求按照《电信和互联网企业网络数据安全合规性评估要点》完成数据安全合规性评估，于数据安全公共服务平台（ds.cisms.cn）登记并更新评估完成情况，各项评估要点要求应于11月底完成，未按要求完成的，扣10分。

（三）电信和互联网行业数据合规治理方案

行业数据安全专项治理。2019 年 1 月 25 日，中央网信办、工信部等四部门联合发布《关于开展 App 违法违规收集使用个人信息专项治理的公告》，决定自当年1月至12月，在全国范围内组织开展 App 违法违规收集使用个人信息专项治理行动，并于年底印发《App 违法违规收集使用个人信息行为认定方法》。

其中，工信部开展的“App侵害用户权益专项整治行动”，对236款App运营者下发整改通知书，公开通报56款，下架3款。2019年7月1日，工信部印发《电信和互联网行业提升网络数据安全保护能力专项行动方案》，开展为期一年的专项行动，从完善网络数据安全制度标准、开展合规性评估和专项治理、强化行业网络数据安全管理、推动网络数据安全技术防护能力建设等方面综合推进，有力推动了行业数据安全治理体系构建。2020年5月14日，工信部印发《关于2020年电信和互联网行业网络数据安全管理工作的通知》，明确开展行业数据安全和个人信息保护违法违规行为集中治理、APP违法违规收集使用个人信息专项治理、疫情防控中个人信息安全风险专项排查等相关工作。

数据安全制度标准建设推进。加速推进行业数据安全指导意见的出台，以明确行业数据分类分级、安全评估、安全认证、预警处置等关键制度规范和要求。部署行业按照法律法规要求，健全完善企业内部网络数据全生命周期安全管理制度，并加快完善行业数据安全标准体系。2020年3月4日，工信部印发《工业数据分类分级指南（试行）》，指导工业领域产品和服务全生命周期产生和应用的数据的分类分级工作。4月10日，工信部公示《网络数据安全标准体系建设指南》（征求意见稿），提出“到2021年，初步建立网络数据安全标准体系”，“到2023年，健全完善网络数据安全标准体系”的建设目标。

数据安全标准体系建设工作。工业和信息化部办公厅2020年12月25日印发《电信和互联网行业数据安全标准体系建设指

南》（以下简称《指南》）。《指南》指出，电信和互联网行业数据安全标准体系包括基础共性、关键技术、安全管理和重点领域等标准。其中，基础共性标准包括术语定义、数据安全框架、数据分类分级等，为各类标准提供基础支撑。关键技术标准从数据采集、传输、存储、处理、交换、销毁等全生命周期维度，对数据安全关键技术进行规范。安全管理标准包括数据安全规范、数据安全评估、监测预警与处置、应急响应与灾难备份、安全能力认证等。重点领域标准主要是结合相关领域的实际情况和具体要求，指导行业有效开展重点领域数据安全保护工作。《指南》提出了电信和互联网行业数据安全标准体系建设目标，到 2021 年，研制数据安全行业标准 20 项以上，初步建立电信和互联网行业数据安全标准体系，有效落实数据安全管理要求，基本满足行业数据安全保护需要，推动标准在重点领域中的应用；到 2023 年，研制数据安全行业标准 50 项以上，健全完善电信和互联网行业数据安全标准体系，标准的技术水平、应用效果和国际化程度显著提高，有力支撑行业数据安全保护能力提升。

行业数据安全标准贯彻工作。为贯彻落实《工业和信息化部办公厅关于印发<2021 年基础电信企业行业数据安全标准贯标工作方案>的通知》（工信厅网安函〔2021〕132 号），宣贯解读相关标准，工业和信息化部网络安全管理局于 6 月 28 日召开电视电话会议，解读《2021 年基础电信企业行业数据安全标准贯标工作方案》并宣贯《基础电信企业数据分类分级方法》《基础电信企业重要数据识别指南》《电信和互联网数据安全评估规范》三

项标准。

行业数据安全管理和新技术新业务安全评估工作。2020 年工业和信息化部召开了 2020 年基础企业安全责任考核数据安全管理和新技术新业务安全评估抽查工作部署会，会议要求结合考核要点内容抽查企业数据安全合规性评估报告和新技术新业务安全评估报告。

（四）电信和互联网行业法律法规焦点问题

依据《数据安全法》《电信和互联网用户个人信息保护规定》等法律法规，行业主管部门采取远程检测、现场检查、专项检查等方式开展监督检查，其中，企业数据安全责任落实情况及合规性评估落实情况被作为重点内容，纳入网络信息安全“双随机一公开”检查和基础电信企业网络与信息安全责任考核检查。数据安全事件的监测跟踪和执法调查力度空前加大，对违法违规行为采取约谈、公开通报、行政处罚等措施，并将处罚结果纳入电信业务经营不良名单或失信名单。数据安全投诉、举报机制也在逐步改善。

(本页无正文)

CSTC中国评测

注意事项：

- 未经中国软件评测中心同意，不得用于其它商业运作。
- 未经中国软件评测中心书面批准，不得部分复印报告。

- 单位地址： 北京市海淀区紫竹院路 66 号
- 邮政编码： 100048
- 通信地址： 北京市海淀区紫竹院路 66 号赛迪大厦 4 层
- 电子信箱： zuoran@cstc.org.cn
- 联系电话： 010-88558326